

OWASP Top 10 for LLM Applications - Study Guide

What is OWASP?

OWASP (Open Worldwide Application Security Project) is a non-profit organization dedicated to improving software security through standards, best practices, cheat sheets, and risk frameworks. Its guidance is widely used across the software industry.

Why OWASP for AI?

Traditional web security risks like SQL Injection and XSS do not fully cover LLM applications. OWASP therefore maintains a dedicated Top 10 for LLM Applications describing the most important AI-specific risks.

1. Prompt Injection

Attackers manipulate the model through crafted prompts. Mitigate using input validation, guardrails, instruction hierarchy, and human oversight.

2. Sensitive Information Disclosure

Models may reveal secrets such as API keys, internal documents, or personal data. Mitigate with access control, redaction, and least privilege.

3. Supply Chain Vulnerabilities

Compromised models, libraries, datasets, or packages can introduce risk. Verify dependencies and use trusted sources.

4. Data & Model Poisoning

Malicious data contaminates training datasets or RAG knowledge bases, leading to incorrect or manipulated outputs.

5. Improper Output Handling

Never blindly trust or execute LLM output. Validate structured responses using schemas and approval workflows.

6. Excessive Agency

Giving AI unrestricted permissions can cause harmful actions. Grant only the minimum required permissions.

7. System Prompt Leakage

Hidden instructions may be exposed by attackers. Avoid placing secrets in prompts and enforce prompt protection.

8. Vector & Embedding Weaknesses

Poisoned documents or manipulated embeddings can compromise RAG systems through indirect prompt injection.

9. Misinformation

LLMs can hallucinate and confidently provide false information. Reduce risk using RAG, citations, verification, and human review.

10. Unbounded Consumption

Attackers can abuse token usage or recursive agents to increase cost. Apply rate limits, token budgets, and monitoring.

Analogy

Traditional web apps face SQL Injection and XSS; LLM apps face Prompt Injection, Prompt Leakage, Agent Abuse, and RAG Poisoning. AI security extends cybersecurity rather than replacing it.

Recommended Resources

Read the OWASP Top 10 for LLM Applications, OWASP GenAI Security Project, NIST AI Risk Management Framework, Microsoft AI Security guidance, Anthropic AI Safety research, and Google DeepMind AI Safety publications.

Preparation Checklist

For every OWASP category ask: What is the vulnerability? How is it exploited? Can I demonstrate it? How is it mitigated? Where does it appear in production?